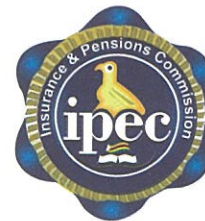


Insurance & Pensions Commission



Circular Number 19 of 2024

14 November 2024

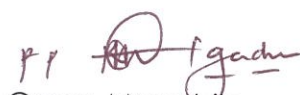
To: Life Insurance Companies
Pension Funds
Pension Funds Administrators

Cc: Life Offices Association (LOA)
Zimbabwe Association of Pension Funds (ZAPF)
Insurance Brokers Association of Zimbabwe (IBAZ)

AMENDMENTS TO THE RISK MANAGEMENT AND CORPORATE GOVERNANCE GUIDELINE FOR PENSION FUNDS

1. The Insurance and Pensions Commission has re-issued the Risk Management and Corporate Governance Directive in terms of new Pensions and Provident Funds Act [Chapter 24:32] as it was previously issued under S.I. 69 of 2020.
2. The following is a summary of the changes made to the re-issued guideline;
 - a) Removing reference to the old Act to the new Act and aligning terms such as Trustee with new terms such as Boards of Funds.
 - b) Aligning board composition, limits to cross directorship and procedure for appointment with the Act.
 - c) Removed reference to S.I. 80 of 2017, which was issued under the repealed Pension and Provident Funds Act and referred to Pension and Provident Funds Regulations, in anticipation of the passage of the new Regulations under the new Act.
3. Please take note of the changes and align the corporate governance requirements to the revised framework.

Yours sincerely


Grace Muradzikwa

COMMISSIONER OF INSURANCE, PENSION AND PROVIDENT FUNDS



INSURANCE AND PENSIONS COMMISSION

Risk Management and Corporate Governance Guideline for the Pensions Industry

April 2020

Table of Contents

1. Definition of Terms.....	4
2. Introduction and Background.....	5
3. Objectives	6
4. Scope of Application and Effective Date	6
5. Building Blocks of a Risk Management System.....	7
6. Risk Management Framework.....	7
7. Board of Fund Members and Board of Directors	8
8. Control Functions	13
9. Risk Management Function	16
10. Compliance Function	19
11. Internal Audit Function.....	26
12. Outsourcing	29
13. Funding and Solvency Risk Management	40
14. Market Risk Management	42
15. Operational Risk Management.....	45
16. Information, Reporting and Communication	47
17. Credit Risk Management.....	48

AUTHORISATION

This Risk Management and Corporate Governance Guideline for the Pensions Industry is issued in terms of Section 5(1)(f)(i) of the Pensions and Provident Funds Act [Chapter 24:32], which empowers the Insurance and Pensions Commission to issue guidelines and standards to govern risk management and corporate governance practices by pension fund and pension administrators.

1. Definition of Terms

Agency Risk means the risk arising from the loss that fund members can experience owing to a decision(s) made by the person(s) administering or managing the fund on behalf of the members. Risks include excessive fees, conflict of interests, biased funding decisions, fraud, misappropriation, and misallocation.

Credit Risk means risk of loss from failures of counterparties such as sponsoring employers and tenants to meet their obligations.

Entity refers to a person, whether natural or legal, who is registered and/or regulated in terms of the Pension and Provident Funds Act [Chapter 24:32] and the regulations made in terms of that Act.

Funding and Solvency Risk means the risk that a fund does not have sufficient assets to meet its liabilities, and the risk of insolvency in the sponsoring employer affecting its ability to fund the pension scheme.

Key Personnel means the Principal Officer, or a person charged with overseeing the day-to-day operations of the entity such as Chief Operating Officer, Chief Executive Officer, Managing Director or whatever title he/she may use and staff members in charge of the finance function, internal audit, actuarial/risk management function, compliance function.

Legal and Compliance Risk the likelihood of adverse consequences arising from the failure to comply with all relevant laws and regulatory requirements. This includes the possibility of incurring losses arising out of litigation.

Liquidity Risk means the risk that an entity will not be able to meet its financial obligations, as and when they fall due, owing to difficulties in converting assets into cash.

Market Risk means risk of losses due to adverse movements in interest rates, exchange rates, equity prices, commodity prices and/or any other market prices.

Material Business Activity is one which has the potential, if disrupted or poorly performed, to affect members' or beneficiaries' interests, or to have a

significant impact on the business operations, reputation, rate of return, profitability or net assets of a fund.

Non-executive Director means an individual charged with providing oversight on the regulated entity who is not involved in the day-to-day management of the entity or has not been so involved at any time during the past three (3) years.

Operational Risk means the risk of losses resulting from inadequate or failed internal processes, people and systems, including Information Communication Technology (ICT) systems, as well as the risks from external events.

An Outsourcing Agreement is an arrangement between the board of an entity and a service provider for the performance of a business activity of the entity.

Reputational Risk means the risk that arises from possible damage to an entity's reputation as a consequence of negative public perception (e.g. among fund members, sponsoring employers or authorities).

Strategic Risk means the risk resulting from poor strategic decisions.

Underwriting Risk means the risk of failure by the fund to have adequate resources to meet claims arising out of insurance products underwritten by the fund such as, group life assurance and annuities paid to pensioners from the fund.

2. Introduction and Background

- 2.1. The Insurance and Pensions Commission has developed this framework for the purpose of providing guidelines to all pension or provident funds and fund administrators (herein after cumulatively referred to as regulated entity or entity) on the minimum requirements for risk management systems and corporate governance.
- 2.2. Risk management refers to the processes of identifying, measuring, monitoring, controlling and reporting of risks. The risk management process does not involve just one policy or procedure performed at a certain point

of time but should be continually operating at all levels of the organisation and involve all staff.

3. Objectives

3.1. The main objective of this guideline is to ensure sound risk management and corporate governance practices within the pensions industry in a bid to provide reasonable assurance regarding the achievement of the following:

-

- a) effective operation and administration of funds;
- b) efficiency and resilience of pensions funds;
- c) sustainability of pensions;
- d) adequacy of pension benefits;
- e) wide coverage of pension services;
- f) affordability of pensions services;
- g) reliability of financial reporting; and
- h) compliance with laws and regulations.

3.2. The attainment of the objectives mentioned above will ultimately improve the protection of fund member interests.

4. Scope of Application and Effective Date

4.1. This guideline shall apply in full to stand-alone self-administered funds and fund administrators excluding life insurers. Self-administered funds under the administration of professional fund administrators/life insurers and insured funds are required to comply with the requirements of this guideline save for those under which exemptions have been allowed. Life assurers administering funds in the Republic of Zimbabwe shall also be required to comply with this guideline to the extent necessary to achieve the objectives of this guideline.

4.2. The guideline shall be read with all the other legislation pertaining to pensions business in Zimbabwe, including Circulars issued by IPEC.

4.3. The guideline becomes operational with effect from 01 July 2020.

4.4. The Commission reserves the right to amend this guideline from time to time.

5. Building Blocks of a Risk Management System

5.1. The following building blocks shall form part of every regulated entity's risk management system:-

- a) A documented and board approved Risk Management Framework covering all the risks the entity is exposed to;
- b) Adequate board and senior management oversight;
- c) Documented and board approved Policy and Procedures Manuals covering all the key activities (functions) of the fund/administrator;
- d) Adequate Control and Monitoring Mechanisms; and
- e) Robust Systems providing Information, Reporting and Communication.

5.2. An entity shall ensure that all the risk management building blocks are put in place in the interest of protecting fund members.

6. Risk Management Framework

6.1. Every entity shall have in place an effective risk management framework which should be reviewed at least once annually. The framework shall cover the strategies, processes, and reporting procedures necessary to identify, measure, monitor, assess, control, and report, on a continuous and *ad hoc* basis, all material risks, at an individual and aggregated level, to which the entity is or could be exposed to, and their interdependencies.

6.2. In other words, the risk management framework should at a minimum include: -

- a) definitions and categorisation of all reasonably foreseeable, current and emerging material risks (including external and internal business specific

- and enterprise-wide risks) to which the entity is exposed to, taking into account the nature, scale, and complexity of the entity and its business;
- b) the approach relating to the identification, assessment, monitoring, management and reporting of each risk, including assignment of specific risk management responsibilities across the fund or administrator.
- 6.3. The risk management framework should foster a risk management system that is well integrated into the organisational structure, culture, and in the decision-making process of the fund.
- 6.4. The risk management systems should be commensurate with the nature, scale and complexity of the fund/administrator, reflecting the scope and degree of sophistication of its activities.

7. Board of Fund Members and Board of Directors

Role of Board....

- 7.1. The Board of Fund of the fund or the Board of Directors of the fund administrator (hereinafter collectively referred to as the board) is ultimately responsible for the risk management system and for ensuring that the entity has in place effective systems and functions to identify, measure and mitigate the material risks it faces.
- 7.2. The board shall be responsible for -
- a) Setting strategic goals, which goals should be consistent with the expected role and activities of the entity and aligning the goals with the entity's objectives.
 - b) Establishing a comprehensive and well-defined risk management framework or strategy that defines the entity's risk appetite, approach to risk and sets out the methods for identifying measuring, managing, and mitigating risks. The risk appetite should be defined in line with the entity's demographic profile, financial resources, business strategies, and management. The framework should clearly identify those responsible for implementation.

- c) Reviewing the risk management framework, considering changes in the risk profile of the business. This process involves understanding the risks assumed; setting acceptable levels of risk; and outlining how these risks will be measured monitored and controlled.
- d) Approving and reviewing the policies and procedures to ensure effective risk management.
- e) Ensuring that the risk management framework is regularly reviewed, at least annually, by competent personnel that are operationally independent of the risk management activities.
- f) Ensuring that there is a process in place for modifying or adapting the strategy as may be required.
- g) Ensuring that key personnel appointed to the entity possess adequate qualifications, expertise, and experience required for the effective execution of the function to which they are appointed. The Board shall, within seven days after appointing key personnel, notify the Commission of such appointment.

7.3. In order for risk assessment to remain effective, the board shall be required to frequently evaluate and record the risks affecting the attainment of its goals and react to changing circumstances and conditions.

7.4. Composition of Board

7.5. The board shall collectively and individually, demonstrate both formal and perceived independence and exercise objective and impartial judgement in the affairs of the entity.

7.6 Every fund shall appoint at least one independent expert member, who shall assist the board in exercising their functions. The appointed person shall not be an officer or employee of the fund.

7.7. No person shall be appointed to the board of a fund or fund administrator if that person;

- a. is a member of the board of another entity that is registered and regulated by the IPEC;
- b. sits on the board of an entity that provide services to the fund or fund administrator.
- c. is a board member of more than three funds.

7.8. The composition of the board shall be as follows : -

- a. for a fund it shall comply with section 22 of the Pensions and Provident Funds Act [Chapter 24:32] as read with Pension and Provident Funds Regulations.
- b. for a fund administrator it shall consist of at least five directors of whom the majority shall be non-executive directors to provide the basis for independent decision-making;
- c. each fund/administrator shall elect responsible persons to be the chairperson and vice chairperson of the Board. The chairperson and vice chairperson shall be appointed on the basis of their expertise and shall not be employees of the fund or fund administrator or assume executive responsibilities.

- 7.8. The board shall establish committees to support it in performing its functions and enhance the oversight and governance of the entity taking into account the nature, size and risk profile. In particular, the board shall, where applicable, establish the following committees:
- a. Audit;
 - b. Risk Management and Compliance; and
 - c. Finance and Investments.
- 7.9. Responsibility for board decision-making shall ultimately rest with the board and the board shall review the performance of its committees at least annually.
- 7.10. The board shall clearly define the mandate, authority, and responsibilities of any established committees, as well as their composition and working procedures.
- 7.11. Members of the board and key personnel of the entity shall be required to be fit and proper. In assessing such fitness and probity, due regard, as appropriate, shall be given to the fitness and probity requirements set out in section 24 of the Pensions and Provident Funds Act [Chapter 24:32].
- 7.12. The board shall develop procedures for independent performance assessment of the board to ensure that fit and proper standards are met on an ongoing basis.
- 7.13. No member of the board or Principal Officer shall begin to exercise any of the functions that come with his or her role unless the Commission approves such an appointment and has responded in writing to such request without any objections. The request for approval of the appointment shall be submitted to the Commission together with the following vetting documents to enable fit and proper assessment:
- a. police clearance issued within a period of six months from the date of his or her appointment or election;

b. in the case of a board corporate, tax clearance certificate; and
Declaration Form in the form set out in the First Schedule to the Pensions Regulations.

7.14. Members of the board and the Principal Officer shall have the necessary competency, skills, expertise and professional experience required for the effective execution of their duties, including policies for performance assessment on an ongoing basis.

Role of Management

7.15. Management shall be responsible for implementing the risk management framework that has been approved by the board. In implementing the framework, management shall have responsibility for translating the risk appetite expressed by the board into a system of risk limitation strategies and controls.

7.16. Management shall also be responsible for disseminating information on risk policies to all levels within the regulated entity and the implementers of the policies. In addition, management shall provide the board with the risk management report which shall include a summary of identified risks, assessment and analysis results, and an action plan for a management approval.

Responsibility of the Board and Management

7.17. The board and management shall be responsible for ensuring that: -
the risk management strategy is documented, communicated to all relevant staff members, and adhered to; there is a clear segregation of duties within the entity. Decision-making, execution, and checking functions shall be assigned to different people; The segregation of duties shall reflect the nature and extent of the entity's functions and risks posed;

- a. a strong internal control culture is developed within the organisation, a central feature, of which, is the establishment of systems for adequate communication of information between different levels of management;
- b. a conflict of interests policy (including disclosure and review procedures) and a code of conduct policy for all staff is put in place; and
- c. policies and practices (including compensation) enforced by the entity do not inadvertently provide incentives or temptations for inappropriate activities.

8. Control Functions

8.1. This part shall apply:

- a) In whole, to fund administrators (excluding insurers) and stand-alone self-administered funds,
- b) To insurers, to the extent that there are additional requirements provided under this part which are not contained in the Guideline on Governance and Risk Management for Insurance Companies,
- c) In part and to the extent that it is necessary to ensure attainment of the objectives of this guideline, to insured funds and self-administered funds that outsource administration services to fund administrators.

8.2. The fund or fund administrator shall establish and maintain the following control functions-

- a) Risk Management function;
- b) Compliance function; and
- c) Internal Audit function.

8.3. Each control function shall be structured such that the function has the necessary authority, independence, resources, expertise, and access to the board or a committee of the board and all relevant employees and information to exercise its authority and perform its responsibilities.

- 8.4. The risk management and compliance functions may be combined where the size of the entity does not warrant the establishment of separate functions.
- 8.5. The control functions shall have independence sufficient to allow them to -
- a) serve as additional critical components of an entity's checks and balances;
 - b) provide an objective perspective on strategies, issues, and potential non-compliance related to its areas of responsibility; and
 - c) implement or oversee the implementation of corrective measures where necessary.
- 8.6. The authority and responsibilities of each control function must be determined and documented in the risk management framework of the entity.
- 8.7. The entity's internal audit function, or an objective, independent, and qualified external reviewer, shall regularly review the risk management and compliance functions.
- 8.8. An independent and objective external reviewer shall review the internal audit function at least once every three (3) years.
- 8.9. The board shall regularly review the performance of each control function, taking into consideration the reviews referred to under paragraph 8.7 and 8.8 above.
- 8.10. The existence of any control function does not relieve the board or senior management of their respective governance and related responsibilities.
- 8.11. The entity may, where appropriate, considering the nature, scale and complexity of the business, risks, legal and regulatory obligations of the entity, outsource a control function.
- 8.12. Each control function shall: -

- a) avoid conflict of interests, and if any conflict cannot be managed, report that conflict to senior management and the board;
- b) comply with the requirements relating to the reporting structures, independence, resources, expertise, its responsibilities and functions; and
- c) be required to carry out whistle blowing responsibilities to the Commission where it becomes aware of any development at the entity that compromises member interests.

8.13. An entity shall also make use of external control mechanisms such as external auditors, actuaries and custodians.

8.14. In addition to working with the internal control mechanisms, independent external parties shall be appointed as part of the risk management of a pension system. Third parties such as external auditors, actuaries and custodians shall be independent and have 'whistle blowing' responsibilities.

Head of Control Function...

8.15. An entity shall appoint a head for each of the control functions.

8.16. The appointment, performance assessment, remuneration, disciplining and dismissal of the head of each control function (other than the head of the internal audit function) shall be done with the approval of, or after consultation with, the board or relevant board committee.

8.17. The appointment or other periodic performance assessment and dismissal of the head of the internal audit function, and his or her remuneration, promotion, demotion or disciplinary actions shall be done by the board, its chairperson or the audit committee.

8.18. An entity may, where appropriate considering the nature, scale and complexity of the fund's business and risks, appoint a person as the head of more than one control function (other than the head of the internal audit function); or

8.19. An entity shall not outsource the head of control function without the approval of the Commission.

8.20. The head of each control function shall: -

- a) regularly report to the board or a committee of the board;
- b) communicate directly and regularly meet (without the presence of senior management) with the chairperson of the board or the committee of the board identified by the board.

8.21. The head of a control function shall report in writing to the board, as well as the Commission, any matter relating to the business of the entity, of which, the head becomes aware in the performance of his/her functions which may compromise the interests of fund members which: -

- a) in the case of any material contravention of the Act, be made within seven (7) days from the date on which he or she becomes aware of it;
- b) in any other case, be made at the first meeting of the board following the contravention; and
- c) in the case of a matter relating to a contravention of the Act which, in the opinion of the head, has not been satisfactorily or appropriately rectified by the board within thirty days after the date on which the report was made to the board, submit a report on the non-rectification to the Commission within 15 days after the expiry of the thirty days period.

9. Risk Management Function

9.1. General Principles

9.1.1. The risk management function shall establish, implement and maintain appropriate mechanisms and activities (including a strategy and operational plan) to: -

- a) assist the board and management in carrying out their respective responsibilities, including providing specialist analysis and performing risk reviews;

- b) identify, measure, monitor and manage risks the entity faces;
- c) establish and maintain an aggregated view of the risk profile of the entity at an enterprise-wide level;
- d) evaluate the internal and external risk environment on an on-going basis to identify and assess potential risks as early as possible;
- e) consider risks arising from remuneration arrangements and incentive structures within the entity and in respect of persons to whom activities have been outsourced;
- f) conduct regular stress testing and scenario analyses, including in respect of outliers or matters with low probability but high potential impact;
- g) regularly report to management, heads of control functions and the board on the fund's risk profile, and the details of the risk exposures facing the entity and related mitigation actions;
- h) report material changes affecting the fund's risk management system to the board to ensure that the framework is maintained and improved; and
- i) conduct regular assessments of the risk management function and the risk management system and implement or monitor the implementation of any improvements.

9.1.2. The risk management system shall be reviewed regularly by the internal audit function or an independent and objective external party of the entity to ensure that the system remains effective and that any necessary modifications are identified and effected in a timely manner.

9.1.3. The risk management function shall promptly inform the board of any circumstance that may have an adverse material effect on the risk management system of the fund.

9.1.4. The risk management function shall have access to and report to the board or a committee of the board identified by the board on -

- a) the strategy of the risk management function;
- b) the risk management function's operational plan, including specific annual or other periodic goals being pursued and the performance against such goals;
- c) information on the risk management function's resources, including an analysis on the appropriateness of these resources;
- d) an assessment of the fund's risk profile and changes thereto;
- e) where appropriate, an assessment of pre-defined risk limits;
- f) where appropriate, risk management matters in relation to strategic affairs such as corporate strategy, mergers and acquisitions, and major projects and investments;
- g) an assessment of risk events and the identification of appropriate remedial actions; and
- h) processes for ensuring adequate contingency planning, business continuity and crisis management.

9.2. Risk Management Reporting Requirements

9.2.1. The head of the risk management function shall have the authority and obligation to inform the board promptly of any circumstance that may have a material effect on the risk management system of the entity and detrimental impact to the entity or fund members. The chairperson of the board will be required to report to the Commission of any such occurrence.

9.2.2. The board shall provide the Commission with a risk management declaration within ninety (90) days after the end of the fund's financial year indicating that-

- a) The entity has systems in place for the purpose of ensuring compliance with this guideline;
- b) The board is satisfied with the efficacy of the processes and systems surrounding the production of financial information of the fund;

- c) The entity has in place a risk management strategy, developed in accordance with the requirements of this guideline, setting out its approach to risk management; and
- d) The systems that are in place for managing and monitoring risks, and the risk management system, are appropriate to the fund, having regard to such factors as the size, and complexity of the fund's operations.

10. Compliance Function

10.1. General Principles

- 10.1.1. Regulated entities shall be required to have an effective compliance management system capable of assisting the entity to meet its internal and external obligations. The compliance management system shall promote and sustain a corporate culture of compliance and integrity.
- 10.1.2. The board shall ensure that the entity complies with all applicable laws, regulations, supervisory decisions and internal policies, and conducts its business ethically and responsibly.
- 10.1.3. The board shall ensure that the entity has in place effective systems for detecting, preventing, and combatting all activities related to money laundering and the financing of terrorism in compliance with the Money Laundering and Proceeds of Crime Act [Chapter 9:24].
- 10.1.4. The entity shall have in place a robust well positioned, resourced, and properly authorised, and staffed compliance function.
- 10.1.5. The compliance function shall provide the board with independent assurance in respect of the fund's governance, including its risk management and internal controls. The "Three lines of defence" model outlined in this guideline provides a benchmark model for good corporate governance.

10.1.6. The compliance function shall be required to be independent from management and not be involved operationally in the business. An effective compliance function shall be headed by a suitably experienced and qualified person, having regard to such factors as the size, business mix and complexity of the fund's operations.

10.1.7. The compliance management system shall be reviewed, at most, every three (3) years by the internal audit function or an independent and qualified objective external reviewer of the entity to ensure that the system remains effective and that any necessary modifications are identified and effected in a timely manner.

10.2. General Compliance Responsibilities

10.2.1. To effectively identify and actively prevent and eliminate compliance risk, an entity shall establish an effective compliance management system.

10.2.2. All staff in an entity shall be responsible for compliance. An entity shall cultivate a good compliance culture, enhance the compliance awareness of all employees, and regard the compliance culture construction as an important part of the building of the corporate culture.

10.2.3. Management shall set the tone for compliance from the top. The board and the management-

- a) shall advocate ethics and values of honesty and good faith;
- b) shall advocate such philosophies as voluntary compliance and compliance bringing about values; and
- c) shall make internal compliance management and external supervision interact well with each other.

10.3. Compliance Function Responsibilities

10.3.1. The compliance function shall establish, implement and maintain appropriate mechanisms and activities to: –

- a) assist the board and senior management in carrying out their respective responsibilities;
- b) establish, implement and maintain a risk-based compliance plan;
- c) promote a compliance culture that values responsible conduct and compliance with internal and external obligations;
- d) identify, assess and report on key legal and regulatory obligations and the risks associated therewith, including obligations under the Act and any other applicable laws;
- e) assess the appropriateness of policies, processes, and controls in respect of key areas of internal and external obligations including, legal, regulatory, and ethical obligations and the effective monitoring thereof by the fund;
- f) ensure that regular training is conducted on key internal, legal and regulatory obligations particularly for employees in positions of trust or responsibility or who are involved in activities that have significant legal or regulatory risk;
- g) facilitate the confidential reporting by employees of concerns, shortcomings or potential non-compliance in respect of the fund's policies, legal or regulatory obligations, or ethical considerations;
- h) monitor instances of non-compliance, and ensure that adequate disciplinary actions are taken where appropriate and any necessary reporting to the Commission or other relevant regulatory authorities is made; and
- i) conduct regular assessments of the compliance function and the compliance policies and systems and implement or monitor needed improvements.

10.4. Compliance Responsibilities of the Board

10.4.1. The board is ultimately responsible for the effectiveness of the entity's compliance management and shall perform the following compliance duties: -

- a) Examining and approving compliance policies, supervising and evaluating their implementation annually.
- b) Deliberating and verifying the annual and semi-annual compliance report of the entity.
- c) Examining and approving the annual compliance report of the entity, presenting such report to the Commission and taking measures to settle non-compliance referred to in such a report;
- d) Approving such issues as the appointment, dismissal and remuneration of the head of compliance function;
- e) Approving the structure and responsibilities of the compliance function;
- f) Ensuring that the head of the compliance function can independently communicate with the board, the audit committee or any other special committee of the board; and
- g) Other compliance duties as stipulated in the rules of the fund or service level agreement as appropriate.

10.4.2. The board shall grant suitable authority to the compliance function, including authority to: -

- a) Access and review any records or information of the entity which the compliance function deems necessary to carry out its reviews;
- b) Undertake on the compliance function's initiative, a review of any area or any function consistent with its mission;
- c) Require appropriate management responses to compliance reports, including development of appropriate remedial action; and

- d) Decline doing a review, or taking on any other responsibilities requested by management, if the compliance function believes this is inconsistent with its mission or with the strategy and compliance plan approved by the board. In any such case, the compliance function shall inform the board and seek its guidance.

10.4.3. The entity may, considering its actual situation, appoint other special committees set up by the board to perform the compliance duties specified above.

10.5. Compliance Responsibilities of the Principal Officer

10.5.1. The principal officer of an entity shall perform the following compliance duties in accordance with the decisions made by the board:-

- a) setting up and improving the compliance management organisational structure;
- b) appointing, subject to the approval of the board, the head of the compliance function;
- c) establishing the compliance function;
- d) providing sufficient conditions for the compliance function to perform its duties;
- e) Examining the compliance policies presented by the head of the compliance function and implementing them upon approval of the board;
- f) Through the head of compliance function, identifying and evaluating compliance risks of the entity at least semi-annually, as well as verifying the compliance risk management plan of the following year;
- g) Verifying the annual and semi-annual compliance reports and submitting them to the audit committee of the board;
- h) After finding out any non-compliant operational and management behaviour, promptly taking remedial measures; and

- i) Other compliance duties that are stipulated in the rules or determined by the board.

10.6. Compliance Reporting Requirements

- 10.6.1. An entity shall set down compliance policies and shall submit them to the Commission after they are deliberated on and approved by the board.
- 10.6.2. A compliance policy, shall at least contain the following -
 - a) The entity's objective and basic principles of compliance management;
 - b) The compliance culture advocated by the entity;
 - c) The compliance duties assumed by the board and senior managers;
 - d) The framework of compliance management and channels for reporting information;
 - e) The status and duties of the compliance function; and
 - f) The major procedures for identifying and managing compliance risk.
- 10.6.3. Every entity shall in addition to the general compliance policy have a policy on money laundering and terrorist financing risk assessment and risk mitigation
- 10.6.4. An entity shall, on an annual basis, evaluate its compliance policies and shall, considering the actual needs, revise them.
- 10.6.5. The head of the compliance function shall have access to and report to the board and/or relevant committees or sub-committees on matters such as: -

- a) Formulation, evaluation and revision of compliance policies;
- b) Assessment of the key compliance risks the entity faces and the steps being taken to address them;
- c) Assessment of how the various parts of the fund/administrator (e.g. investments, communication with fund members) are performing against compliance standards and goals;
- d) Compliance issues involving management or persons in positions of major responsibility within the entity, and the status of any associated investigations or other actions being taken;
- e) Fines or other disciplinary actions taken by the Commission or any other regulator in respect of the entity or any employee;
- f) Any factors that may be adversely affecting the compliance function's independence, objectivity or effectiveness;
- g) Compliance trainings; and
- h) Other issues as deemed necessary.

10.6.6. The head of the compliance function shall have the authority and obligation to promptly inform the chairperson of the board directly in the event of any contravention of the Pension and Provident Funds Act [Chapter 24:32] and any other major non-compliance by a member of management or any staff member for that matter or a material noncompliance by the entity with an external obligation. This shall apply where he or she believes that management is not taking the necessary corrective actions, and a delay would be detrimental to the entity or its members.

10.6.7. The chairperson of the board will be required to report to the Commission any such occurrence and institute an investigation and/or remedial action within seven (7) days.

10.6.8. The board shall provide the Commission with a compliance function declaration within 90 days after the closure of the entity's financial year stating that, to the best of its knowledge and belief, having made appropriate enquiries: -

- a) The entity has systems in place for the purpose of ensuring compliance with this guideline; and
- b) The systems that are in place for managing and monitoring risks, and the compliance function, are appropriate to the entity, having regard to such factors as the size, business mix and complexity of the entity's operations.

11. Internal Audit Function

11.1. General Principles

11.1.1. The Internal audit function shall at least: -

- a) establish, implement and maintain a risk-based audit plan;
- b) review and evaluate the adequacy and effectiveness of the entity's policies and processes and the documentation and controls in respect of these;
- c) review levels of compliance with established policies, processes, and controls;
- d) evaluate the reliability and integrity of information;
- e) monitor that the identified risks and the agreed actions to address them are accurate, complete and current;
- f) evaluate the internal controls relating to governance, operations and information systems in place to verify the safeguarding of the entity's assets;
- g) evaluate the effectiveness of the governance framework; and

h) evaluate the adequacy and effectiveness of the entity's risk management, and compliance functions.

11.1.2. In carrying out the above tasks, the internal audit function shall ensure that, over a reasonable period, all material areas of risk and obligation of the entity is subject to appropriate audit or review including, but not limited to: –

- a) market, credit, liquidity, operational, and regulatory and compliance (including reputational) risk;
- b) accounting and financial policies and whether the associated records are complete and accurate;
- c) In collaboration with the compliance function, the extent of compliance by the entity with applicable laws, regulations, rules, and guidelines from all relevant regulatory authorities;
- d) intra-group transactions, including intra-group risk transfer and internal pricing;
- e) adherence by the entity to its remuneration policy;
- f) the reliability and timeliness of escalation and reporting processes, including whether there are confidential channels for employees to report concerns or non-compliance, and whether these are properly communicated, offer the reporting employee adequate protection from retaliation, and result in appropriate follow up; and
- g) the extent that any non-compliance with internal policies or external legal or regulatory obligations are documented, and appropriate corrective or disciplinary measures are taken, including in respect of individual employees involved.

11.1.3. The internal audit function shall have access to and, at least annually, report to the board or the audit committee on: –

- a) the strategy of the function;

- b) the function's audit plan, detailing the proposed areas of audit focus;
- c) an assessment of the extent of achievement of the goals set out in the audit plan;
- d) information on its resources, including an analysis on the appropriateness of those resources;
- e) any factors that may impinge on the internal audit function's independence, objectivity, or effectiveness;
- f) material findings from audits or reviews conducted;
- g) material deficiencies of the internal control system, or of compliance with internal policies and procedures or external legal or regulatory obligations and include agreed management action to remedy all identified deficiencies.; and
- h) the extent of management compliance and progress with previously agreed upon corrective or risk mitigating measures.

11.2. Reporting Requirements

- 11.2.1. The head of the internal audit function shall report functionally to the board or to the audit committee and administratively to the principal officer.
- 11.2.2. In its reporting, the internal audit function shall cover matters such as: -
 - a) The function's annual or other periodic audit plan, detailing the proposed areas of audit focus;
 - b) Any factors that may be adversely affecting the internal audit function's independence, objectivity or effectiveness;
 - c) Material findings from audits or reviews conducted; and
 - d) The extent of management's compliance with agreed upon corrective or risk mitigating measures in response to identified control deficiencies, weaknesses or failures, compliance violations or other lapses.

- 11.2.3. In addition to periodic reporting, the head of internal audit shall be authorised to communicate directly, and meet periodically, with the head of the audit committee or the chairperson of the board without the presence of management.
- 11.2.4. The internal audit function shall also furnish the Commission with an audit report detailing its findings within thirty days after conduct of an audit of any function. However, should there be material issues which prejudice fund members or threaten viability of the fund or the administrator, the internal audit shall immediately report to the Commission.
- 11.2.5. The board shall provide the Commission with an internal audit declaration within ninety (90) days after the closure of the entity's financial year stating that, to the best of its knowledge and belief, having made appropriate enquiries that: -
- a) The entity has adequate systems in place for the purpose of ensuring compliance with this guideline;
 - b) The systems that are in place for managing and monitoring risks, and the internal audit function, are appropriate to the entity, having regard to such factors as the size, business mix and complexity of the entity's operations.
- 11.2.6. The Head of Internal Audit Function shall be expected to be a member of the local Chapter of the Institute of Internal Auditors Zimbabwe or strive to join the same within a period of one to two years from the effective date of this framework.

12. Outsourcing

12.1. General Principles

- 12.1.1. For the purposes of application of this section, the term outsourcing shall apply to any services provided by any external legal entity (natural person or corporate), including companies related to the entity in question such as

sponsoring employers, the holding company and subsidiaries of the holding company or the administrator. An entity shall assess the degree of materiality in outsourcing to different service providers and must ensure that such services providers are registered in accordance with the laws governing the provision of the services that they offer.

- 12.1.2. The extent and degree to which this guideline is implemented is expected to be commensurate with the materiality of the outsourcing. In assessing materiality, the Commission recognises that qualitative judgement is involved, and the circumstances faced by individual entities may vary.

Factors that an entity shall consider include:-

- a) Potential impact of the outsourcing on earnings, solvency, liquidity, funding and risk profile;
- b) Impact on the entity's reputation, and ability to achieve its business objectives, strategy and plans, should the service provider fail to perform the service;
- c) Aggregate exposure to a particular service provider in cases where the entity outsources various functions to the same service provider; and
- d) Ability to maintain appropriate internal controls and meet regulatory requirements, if there were operational problems faced by the service provider.

- 12.1.3. While funds or administrators may consider outsourcing different business management functions to reduce their costs and achieve strategic objectives, care will need to be taken on the activities or functions outsourced to different service providers.

- 12.1.4. There is need to maintain some degree of independence to ensure different functions which are meant to be independent are not carried out by the same service provider. For example, if the internal audit function and

the risk management function are outsourced to the same service provider it may compromise the role of these functions.

12.1.5. An entity shall undertake periodic reviews of its outsourcing arrangements to identify new material outsourcing risks as they arise.

12.1.6. An agreement which was previously not material may subsequently become material from incremental activities outsourced to the same service provider or an increase in volume or nature of the activity outsourced to the service provider.

12.1.7. Material outsourcing risks may also arise when the service provider in a material outsourcing plans to sub-contract the service or makes significant changes to its sub-contracting arrangements.

12.1.8. An entity shall consider materiality at both the individual and consolidated basis, i.e. together with the entity's branches and corporations under its control.

12.2. Role of the Board and Senior Management

12.2.1. The board and senior management of an entity retain ultimate responsibility for the effective management of risks arising from outsourcing and for approving the outsourcing arrangements.

12.2.2. The Principal Officer shall be responsible for submitting the outsourcing arrangements to the Commission once the entity has made the decision to outsource and after every review of the outsourcing arrangements. The Commission reserves the right to raise any concerns that it may have with the outsourcing arrangement with the board. The Board shall be obliged to take such concerns into account in maintaining the outsourcing arrangement and as soon as practically possible, though no later than thirty days, provide a response to the IPEC on how the concerns have been addressed.

12.2.3. While a fund may delegate its day-to-day operational duties to the service provider, the responsibilities for effective due diligence, oversight and management of outsourcing and accountability for all outsourcing decisions, rest with the fund, its board and senior management.

12.2.4. The board, or a committee delegated by it, is responsible for: -

- a) approving a framework to evaluate the risks and materiality of all existing and prospective outsourcing and the policies that apply to such arrangements;
- b) assessing whether the business activity to be outsourced is material, the cost of the outsourcing arrangement, and the degree of difficulty (including time taken) to find an alternative service provider or to bring the service in-house.
- c) laying down the appropriate approval authorities for outsourcing depending on the nature of risks and materiality of the outsourcing;
- d) assessing management competencies for developing sound and responsive outsourcing risk management policies and procedures as commensurate with the nature, scope;
- e) assessing complexity of the outsourcing arrangements; undertaking regular review of outsourcing strategies and arrangements for their continued relevance, and safety and soundness; and
- f) reviewing a list of all material outsourcing and relevant reports on outsourcing.
- g) developing the outsourcing policy that should contain considerations of the impact of outsourcing on its business and the reporting and monitoring arrangements to be implemented once outsourcing is undertaken.

12.2.5. Senior management is responsible for: -

- a) Evaluating the risks and materiality of all existing and prospective outsourcing, based on the framework approved by the board;
- b) developing and implementing sound and prudent outsourcing policies and procedures commensurate with the nature, scope and complexity of the outsourcing;
- c) reviewing periodically the effectiveness of policies and procedures;
- d) communicating information pertaining to material outsourcing risks to the board in a timely manner;
- e) ensuring that contingency plans, based on realistic and probable disruptive scenarios, are in place and tested; and
- f) ensuring that there is independent review and audit for compliance with set policies.

12.3. Capability of Service Providers

- 12.3.1. In considering, renegotiating or renewing an outsourcing arrangement, an entity shall subject the service provider to appropriate due diligence to assess its capability to employ a high standard of care in performing the service and comply with its obligations under the outsourcing agreement. Signed, written outsourcing agreements will include details on the following
- a) any default arrangements, a dispute resolution process, liability and indemnity provisions, confidentiality requirements, and details of pricing and fee structures.
 - b) audit, monitoring and assessment procedures - specifying service levels and performance requirements need to be clearly laid out. The frequency of reporting against targets shall reflect the level of risk to the entity in the event of the failure of the service provider to perform at a certain level.
 - c) the agreement needs to provide the board of the entity and the pension supervisory authority (where appropriate) with access to

information, including access to the service providers' premises, and the right of the board or pension supervisory authority to require an audit.

12.3.2. Service providers may not charge a fee for such information or access.

Termination provisions need to be transparent and clear to all parties, and business continuity planning included.

12.3.3. A tender process shall be required to be put in place as a good practice component of the due diligence process. All due diligence shall be appropriately documented.

12.3.4. The due diligence shall take into consideration qualitative and quantitative, financial, operational and reputation factors. Compatibility and performance shall be emphasized in the assessment. Where possible, the entity shall obtain independent reviews and market feedback on the service provider to supplement its own findings.

12.3.5. The due diligence shall involve an evaluation of all available information about the service provider such as: -

- a) Establishing, implementing and maintaining a risk-based audit plan to examine and evaluate general or specific areas, including on a preventive basis;
- b) its experience and competence to implement and support the proposed activity over the contracted period;
- c) its financial strength and resources where applicable (the due diligence shall be similar to a credit assessment of the viability of the service provider based on reviews of business strategy and goals, audited financial statements, the strength of commitment of significant equity sponsors and ability to service commitments even under adverse conditions);

- d) its business reputation and culture, compliance, complaints and outstanding or potential litigation;
 - e) its security and internal controls, audit coverage, reporting and monitoring environment;
 - f) its business continuity management;
 - g) its reliance on and success in dealing with sub-contractors; and
 - h) its external factors (such as the political, economic, social and legal environment of the jurisdiction in which the service provider operates, and other events) that may impact service performance.
- 12.3.6. Due diligence undertaken during the selection process shall be documented and re-performed periodically (At least annually) as part of the monitoring and control processes of outsourcing.
- 12.3.7. The due diligence process can vary depending on the nature of the outsourcing arrangement e.g. reduced due diligence may be sufficient where no developments or changes have arisen to affect an existing outsourcing arrangement or where the outsourcing is to a member of the group.
- 12.3.8. An entity shall ensure that the information used for due diligence evaluation is current and shall not be more than twelve (12) months old.

12.4. Outsourcing Agreement

- 12.4.1. Contractual terms and conditions governing relationships, functions, obligations and responsibilities of the contracting parties in the outsourcing shall be carefully and properly defined in written agreements.
- 12.4.2. The detail in these agreements shall be appropriate for the nature and materiality of the arrangement. They shall also be vetted by a competent authority e.g. the fund's legal counsel on their legal effect and enforceability.

12.4.3. An entity shall ensure that every outsourcing agreement addresses the risks and risk mitigation strategies identified at the risk evaluation and due diligence stages. Each agreement shall run for a maximum period of three years and may thereafter be renegotiated and renewed to enable the entity to retain an appropriate level of control over the outsourcing and the right to intervene with appropriate measures to meet its legal and regulatory obligations.

12.4.4. The agreement shall also not hinder the Commission in the exercise of its supervisory powers over the entity and right of access to information on the entity and the service provider. It shall at the very least, have provisions pertaining to: -

- a) The scope of the outsourcing service; and
- b) Performance standards defined in terms of, for example, service levels and performance targets; service availability, reliability, stability and upgrade.

12.5. Confidentiality and Security

12.5.1. As public confidence in funds is a cornerstone in the stability and reputation of the pensions industry, it is vital that an entity satisfies itself that the service provider's security policies, procedures and controls will enable the entity to protect confidentiality and security to customer information;

12.6. Business Continuity Management

12.6.1. An entity shall ensure that its business continuity preparedness is not compromised by outsourcing. In that regard, the entity shall take steps to evaluate and manage the interdependency risk arising from the outsourcing arrangement such that the entity remains able to conduct its business smoothly in the event of disruption, unexpected termination of the outsourcing arrangement or liquidation of the service provider.

12.6.2. These shall include steps to: -

- a) Determine that the service provider has in place satisfactory business continuity plans (BCP) commensurate with the nature, scope and complexity of the outsourcing.
- b) Proactively seek assurance on the state of BCP preparedness of the service provider.
- c) Ensure the service provider is able to isolate and clearly identify the entity's information, documents and records, and other assets such that in adverse conditions, all documents, records of transactions and information given to the service provider, and assets of the funds, can either be removed from the possession of the service provider in order to continue its business operations, or deleted, destroyed or rendered unusable.

12.7. Monitoring and Control

- 12.7.1. An entity shall establish a structure for the management and control of outsourcing. Such a structure will vary depending on the nature, scope and complexity of the outsourced activity.
- 12.7.2. As outsourcing relationships and interdependencies increase in materiality and complexity, a more rigorous risk management approach shall be adopted. An entity also must be more proactive in its relationship with the service provider e.g. having frequent meetings, to ensure that performance levels are upheld.
- 12.7.3. An entity shall ensure that outsourcing agreements with service providers contain provisions to address their monitoring and control of outsourced activities.

12.8. Audit and Inspection

- 12.8.1. Outsourcing should not interfere with the ability of the entity to effectively manage its activities or impede the Commission in carrying out its supervisory functions and objectives.

12.8.2. Every entity is therefore required to take steps to ensure that outsourcing agreements with the service provider include clauses that allow: -

- a) The entity to conduct audits on the service provider, whether by its internal or external auditors, or by agents appointed by the entity; and to obtain copies of any report and finding made on the service provider in conjunction with the service performed for it; and
- b) IPEC, or any agent appointed by IPEC, to access both the service provider and the entity to obtain records and documents, of transactions, and information of the entity given to, stored at or processed by the service provider and the right to access any report and finding made on the service provider.

12.9. Dispute Resolution

12.9.1. Outsourcing Agreements shall specify the resolution process, events of default, and the indemnities, remedies and recourse of the respective parties in the agreements.

12.10. Default Termination and Early Exit

12.10.1. An entity shall have the right to terminate the agreement in the event of default, including circumstances when the service provider undergoes a change in ownership, becomes insolvent, goes into liquidation, receivership or judicial management, whether in Zimbabwe or elsewhere; or when there has been a breach of security, confidentiality or demonstrable deterioration in the ability of the service provider to perform the service as contracted.

12.10.2. The minimum period to execute a termination provision shall be specified.

12.11. Sub-contracting

12.11.1. An entity should retain the ability to maintain similar control over its outsourcing risks when a service provider uses a subcontractor as in its agreement with the service provider.

- 12.11.2. Agreements shall have clauses setting out the rules and limitations on sub-contracting.
- 12.11.3. An entity may want to include clauses making the service provider contractually liable for the capability of the sub-contractor it selects and for compliance with the provisions in its agreement with the service provider, including the prudent practices set out in this guideline, and particularly those relating to security and confidentiality, audit and inspection as well as business continuity management.
- 12.11.4. For material outsourcing arrangements, the sub-contracting of all or substantially all a service provided, should be subject to prior approval of the board.

12.12. Applicable Laws

- 12.12.1. Agreements should include choice-of-law provisions, agreement covenants, and jurisdictional covenants that provide for adjudication of disputes between the parties under the laws of a specific jurisdiction.
- 12.12.2. Each agreement should be tailored to address additional issues arising from country risks and potential obstacles in exercising oversight and management of the arrangements when outsourcing to a service provider outside Zimbabwe.

12.13. Legal and Regulatory Obligations

- 12.13.1. Outsourcing does not diminish the obligations of the entity, and those of its board and senior management, to comply with relevant laws and regulations of Zimbabwe. Risk management practices shall therefore include steps to ensure that all relevant laws, regulations, guidelines and other directions, as well as any condition of approval, licensing or registration, continue to be met.
- 12.13.2. The Commission's supervisory powers over funds and fund administrators;

and the ability to carry out supervisory functions shall also not be hindered, whether the service provider is located within Zimbabwe or elsewhere.

12.13.3. Every entity shall conduct its business with integrity and competence. Hence an entity shall not engage in outsourcing that results in its internal control, business conduct or reputation being compromised or weakened.

12.13.4. An entity shall take steps to ensure that the service provider employs a high standard of care in performing the service as if the activity were not outsourced and conducted within the entity.

12.13.5. The entity also needs to maintain the capability and appropriate level of monitoring and control over outsourcing, such that in the event of disruption or unexpected termination of the service, it remains able to conduct its business with integrity and competence.

13. Funding and Solvency Risk Management

13.1.1. Funds that offer defined benefits or guarantees shall maintain an appropriate level of assets to meet the liabilities corresponding to the financial commitments or obligations which arise out of the pension arrangement. Such funds shall be required to establish a funding and solvency policy.

13.1.2. The funding and solvency policy shall set out the mechanisms for monitoring the funding level and identifying the main funding and solvency risks to be monitored and disclosed to relevant parties.

13.1.3. At a minimum, the policy shall set out the valuation methods for calculating the funding level (the ratio of assets to liabilities), the target funding level, and the means through which funding gaps will be closed, the amortisation or recovery period for addressing the underfunding, and the procedures to be followed to address a situation of overfunding, both on an ongoing basis and if the fund is dissolved.

13.1.4. The s policy shall also establish a procedure to collect late contributions from the sponsoring employer or/and fund members, including litigation where appropriate.

13.1.5. The funding and solvency policy shall be reviewed regularly by the board, and at least annually.

13.1.6. When laying out its funding and solvency policy, the board shall consider the following issues: -

- a) the nature of the benefit promise, and in particular, the extent to which accrued and future benefits, retirement ages and other fund parameters affecting pension benefits may be altered;
- b) the sources of financing for the fund, including an assessment of the financial strength of the sponsoring employer, where appropriate;
- c) the extent to which the fund itself or its sponsoring employer is liable for any guarantees inherent in the fund design;
- d) the presence of external forms of solvency and benefit protection, such as insolvency guaranty arrangements which protect benefits against the bankruptcy of the fund or the sponsoring employer.

13.1.7. A key component of Funding and Solvency policy is the procedure to be followed in case of underfunding, if underfunding is allowed to a certain level or for a limited period.

13.1.8. The following are some of the different mechanisms permitted for correcting underfunding: -

- a) the payment of a lump sum or contingent financial commitments by the sponsoring employer,
- b) an increase in future contributions by the sponsor or/and fund members, and
- c) adjustments in future benefit accruals and other benefit parameters such as the retirement age.

- 13.1.9. When monitoring the funding level of the fund, the board should rely on the advice of an actuary.
- 13.1.10. Such monitoring shall include a spot check on the current funding level, but also, stochastic and scenario or stress-testing to assess the fund's resilience to withstand major shocks in the future (including mortality and longevity risk).
- 13.1.11. An actuarial valuation needs to be performed regularly and should also be subject to an independent actuarial review.

14. Market Risk Management

- 14.1.1. Market risk is a major challenge for any entity and therefore shall be a key element of their risk management systems. Appropriate mechanisms are therefore required for mitigating effects of market risk.
- 14.1.2. An investment policy is a key mechanism for identifying and managing market risk. Regulated entities shall have a written investment policy in place, covering at a minimum strategic asset allocation, performance objectives, any broad decisions regarding tactical asset allocation, and trade execution, the use of external managers and establishing mechanisms for monitoring the costs of their services.
- 14.1.3. A socially responsible investment policy shall also be added to the overall investment strategy, outlining how the entity intends to consider environmental, social and governance risks.
- 14.1.4. Entities need to have a clear understanding of the overall investment strategy that they have in place directly and /or through appointed investment managers and of the risks in the strategy. The written investment policy shall be set up and reviewed regularly by the board, and at least annually.
- 14.1.5. Given the specific nature and complexity of some financial instruments, in particular, alternative investments such as hedge funds and private equity,

the investment policy shall specifically address how the underlying risks of these instruments will be monitored, evaluated and managed.

14.1.6. The key way to manage market risk is through the entity's investment policy – which needs to be consistent with the Commission's investments guidelines as well as the prudent person rule and the objectives of the entity (i.e. with the characteristics of the liabilities, maturity of obligations, liquidity needs, risk tolerance etc.).

14.1.7. An investment policy for each entity shall contain the following elements: -

- a) Investment objectives;
- b) Asset allocation;
- c) Diversification;
- d) Liquidity need;
- e) Valuation methodology;
- f) Asset Liability Matching targets (where appropriate);
- g) Performance measurement, monitoring and benchmarking;
- h) Control procedures, including risk tolerances / risk monitoring procedures;
- i) Reporting format and frequency; and
- j) Investment in alternative assets.

14.1.8. The investment policy for funds in which members make investment choices shall ensure that an appropriate array of investment options, is provided to members and that members have access to the information necessary to make investment decisions, and the investment policy shall classify the investment options according to the market risk that members bear.

14.1.9. Investment in certain asset classes calls for special risk controls. For instance, alternative investments require an assessment of the extent to which they fit with the fund's overall strategy, diversification objective and risk profile.

- 14.1.10. Funds and Fund Administrators need to have a clear understanding of the risk characteristics of any alternative investments and of how they contribute to the overall risk of the fund.
- 14.1.11. Funds and Fund Administrators should have confidence in the asset managers of funds they invest in and pay particular attention to reports and valuations of funds.
- 14.1.12. Contract terms (lock up periods etc.) also require checking, and particular attention given to valuation policies of unlisted assets during volatile market conditions. Consideration also needs to be given to liquidity management in relation to infrastructure or other private asset investments.
- 14.1.13. External investment managers need to provide timely and sufficient information to the entity so that the entity can properly monitor, manage and control the risks of these investments individually and as part of the complete portfolio.
- 14.1.14. A key driver of the asset strategy adopted by an entity offering defined benefits or guarantees will be its liabilities profile, and the need to ensure that it holds sufficient assets of appropriate nature, term and liquidity to enable it to meet those liabilities as they become due.
- 14.1.15. Detailed analysis and management of this asset/ liability relationship will therefore, be a pre-requisite to the development and review of investment policies and procedures which seek to ensure that the entity adequately manages the investment - related risks to its solvency.
- 14.1.16. The analysis will involve, inter alia, the testing of the resilience of the asset portfolio to a range of market scenarios and investment conditions, and the impact on the funds' solvency position.
- 14.1.17. Given that the investment strategies of DC funds may involve specific risks,

specific internal controls may be required. For example, if the fund invests wholly or significantly through a single investment vehicle, this would need to be reviewed carefully.

15. Operational Risk Management

- 15.1.1. Operational risk is the risk resulting from inadequate or failed internal processes, people and systems or from external events.
- 15.1.2. Such risks include administrative errors (for example arising from the wrongful assignment of contributions), IT errors or failures (leading to data loss or trading mistakes), as well as the more serious risk of fraud and external risks such as contagion from related parties facing financial difficulties, political instability, natural disasters (such as damage to buildings due to fire, floods or earthquakes) and crime (burglary or theft of property).
- 15.1.3. An operational risk management system shall be drawn up, identifying a set of procedures, which include procedures to define, identify, assess, monitor and control operational risk. All key functional areas shall be guided by documented policy and procedure manuals that are approved at Board level.
- 15.1.4. This includes coverage of ICT risks and business continuity plan. ICT risk, a subset of operational risk, is the risk arising from inadequate information technology and processing in terms of manageability, exclusivity, integrity, infrastructure, controllability and continuity.
- 15.1.5. Models which attempt to quantify the level of future operational risk may be developed. Quantification can be used to assess the efficiency of the entity in controlling risks and /or in providing an estimation of the capital required to absorb potential losses from operational risk events.
- 15.1.6. The effectiveness of the operational risk management quantification could be measured through stress-tests or by a back testing of the model's outputs in a reasonable time horizon.

- 15.1.7. With all types of financial services now highly dependent on technology, internal controls are needed to verify the security of the ICT systems. ICT risks include risks of error, fraud, negligence, and chance mishaps (such as system crashes), the concentration of data, which can weaken the security of information and the use of complex applications which can result in the repetition of problems.
- 15.1.8. Controls are needed to ensure the physical and logistical security of data, including the protection of files and software. The information processes, operational software systems, and accounting and financial reporting systems shall be regularly reviewed.
- 15.1.9. Contingency plans using an alternate off-site facility, including the recovery of critical systems supported by an external service provider, are also required.
- 15.1.10. Controls over information systems and technology would normally include both general and application controls. General controls are controls over computer systems (for example, mainframe, client/server, and end - user workstations) and ensure their continued, proper operation.
- 15.1.11. Application controls are computerised steps within software applications and other manual procedures that control the processing of transactions and business activities, including, for example, edit checks and specific logical access controls unique to a business system.
- 15.1.12. Necessary protection measures will include ICT security requirements (data protection, firewalls); data backup; system recovery; password controls (including a password policy addressing password strength and complexity etc.).
- 15.1.13. Monitoring and incident management controls are also essential.
- 15.1.14. In addition to the risks and controls above, inherent risks exist that are associated with the loss or extended disruption of services caused by

factors beyond the organisation's control hence the need for contingency plans. Business resumption plans must be periodically tested to ensure the plan's functionality in the event of an unexpected disaster.

15.1.15. The risk from outsourcing activities needs particular attention. The quality of the internal control systems of entity service providers may pose a threat to the entity and thus the interests of fund members and beneficiaries. The oversight of these service providers shall therefore be part of the entity's own risk management system.

15.1.16. Service providers shall be made aware that they are accountable to the board for advice given.

16. Information, Reporting and Communication

16.1.1. Adequate and comprehensive channels for the reporting and communication of internal data, external information (e.g. from service providers and to the IPEC and external market information (in particular to fund members) shall be established, with all information required to be reliable, timely, accessible and consistent. A policy shall also be in place to ensure that confidential information is treated appropriately.

16.1.2. Efficient reporting is an important part of any risk management system. Information needs to be released to the relevant parties in an understandable format, and with due frequency. Separate records shall be kept for each fund or account.

16.1.3. Effective channels of communication are required so that everyone understands their responsibilities and to make sure that relevant information is reaching the appropriate personnel.

16.1.4. Communication lines shall encourage adverse reporting (whistle blowing) particularly when flowing upwards. Internal control deficiencies, or ineffectively controlled risks, shall be reported to the appropriate person(s) as soon as they are identified, with serious matters reported to the board

17. Credit Risk Management

17.1.1. Credit risk is manifesting mainly in form of contribution and rental arrears.

17.1.2. Every entity shall put in place a documented and board approved credit risk management policy. The credit risk management policy shall be reviewed at least annually.

END OF DOCUMENT